



MASTG

Non-random Sources Usage

MASTG-TEST-0208: Insufficient Key Sizes

MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code

MASTG-TEST-0221: Broken Symmetric Encryption Algorithms

MASTG-TEST-0232: Broken Symmetric Encryption Modes

MASTG-TEST-0307: References to Asymmetric Key Pairs Used For Multiple Purposes

MASTG-TEST-0308: Runtime Use of Asymmetric Key Pairs Used For Multiple Purposes

L1 L2 ANDROID MASWE-0020 TEST



MASTG-TEST-0232: Broken Symmetric Encryption Modes

Overview

To test for the [use of broken encryption modes](#) in Android apps, we need to focus on methods from cryptographic frameworks and libraries that are used to configure and apply encryption modes.

In Android development, the `Cipher` class from the Java Cryptography Architecture (JCA) is the primary API that allows you to specify the encryption mode for cryptographic operations. `Cipher.getInstance` defines the transformation string, which includes the encryption algorithm, mode of operation, and padding scheme. The general format is

"Algorithm/Mode/Padding". For example:

```
Cipher.getInstance("AES/ECB/PKCS5Padding")
```

In this test we're going to focus on symmetric encryption modes such as [ECB \(Electronic Codebook\)](#).

ECB (defined in [NIST SP 800-38A](#)) is generally discouraged [see NIST announcement in 2023](#) due to its inherent security weaknesses. While not explicitly prohibited, its use is limited and advised against in most scenarios. ECB is a block cipher mode that operate deterministically, dividing plaintext into blocks and encrypting them separately, which reveals patterns in the ciphertext. This makes it vulnerable to attacks like [known-plaintext attacks](#) and [chosen-plaintext attacks](#).

For example, the following transformations are all [considered vulnerable](#):

- "AES" (uses AES/ECB mode by [default](#))
- "AES/ECB/NoPadding"
- "AES/ECB/PKCS5Padding"
- "AES/ECB/ISO10126Padding"

You can learn more about ECB and other modes in [NIST SP 800-38A - Recommendation for Block Cipher Modes of Operation: Methods and Techniques](#). Also check the [Decision to Revise NIST SP 800-38A, Recommendation for Block Cipher Modes of Operation: Methods and Techniques](#) and [NIST IR 8459 Report on the Block Cipher Modes of Operation in the NIST SP 800-38 Series](#) for the latest information.

Out of Scope: Asymmetric encryption modes like RSA are out of scope for this test because they don't use block modes like ECB.

In the transformation strings like `"RSA/ECB/OAEPPadding"` or `"RSA/ECB/PKCS1Padding"`, the inclusion of `ECB` in this context is misleading. Unlike symmetric ciphers, **RSA doesn't operate in block modes like ECB**. The `ECB` designation is a [placeholder in some cryptographic APIs](#) and doesn't imply that RSA uses ECB mode. Understanding these nuances helps prevent false positives.

Steps

- Run [Static Analysis on Android](#) with a tool such as [semgrep](#) on the app binary, or use [Method Tracing](#) (dynamic analysis) with a tool like [Frida \(Android\)](#), and look for cryptographic functions specifying the encryption mode to insecure modes.

Observation

The output should contain a list of locations where broken encryption modes are used in cryptographic operations.

Evaluation

The test case fails if any broken modes are identified in the app.

Best Practices

MASTG-BEST-0005: Use Secure Encryption Modes

Demos

MASTG-DEMO-0058: Using KeyGenParameterSpec with a Broken ECB Block Mode

MASTG-DEMO-0023: Uses of Broken Encryption Modes in Cipher with semgrep